

GitHub Copilot CAPI & Agent Loop – Customer Security Explainer

GitHub Copilot: CAPI & Agent Loop Security Explainer

This one-page overview is designed for security, risk, and compliance stakeholders. It explains how **GitHub Copilot agents work**, what the **Copilot API (CAPI)** does, and **where security controls are enforced**, using only approved, customer-safe language.

What is CAPI (Copilot API)?

CAPI is GitHub's **internal Copilot service layer**. It is **not a public or customer-callable API**. CAPI acts as the secure control plane between developer tools (such as Visual Studio Code) and the underlying large language models.

CAPI is responsible for:

- Receiving Copilot requests from IDE extensions
- Enforcing enterprise and organization policies
- Applying security and privacy filters
- Routing requests to approved AI models
- Returning responses to the IDE

Customer code and prompts are processed **in real time** and are **not used to train GitHub or third-party models** for Copilot Business and Enterprise customers.

What is the Copilot Agent Loop?

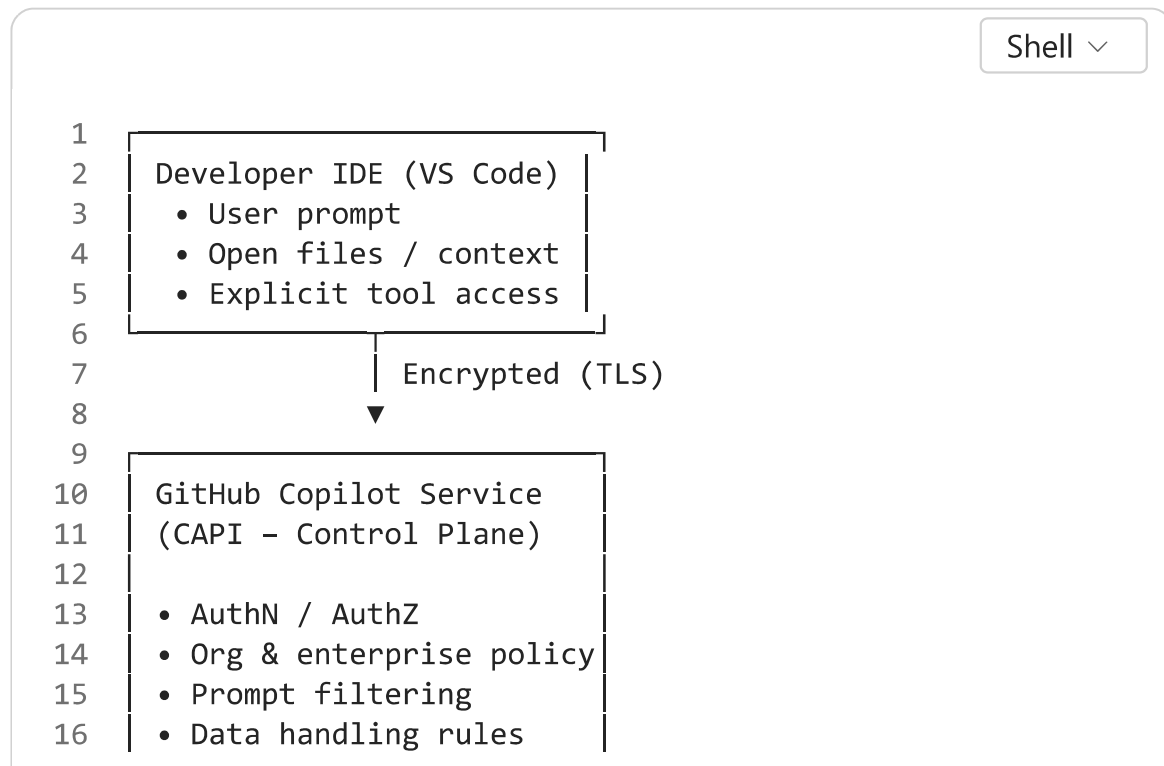
The **agent loop** is the controlled, observable cycle Copilot uses when operating in **Agent mode** (for example, in Visual Studio Code). Rather than a single prompt-response interaction, the agent works through a series of small, auditable steps.

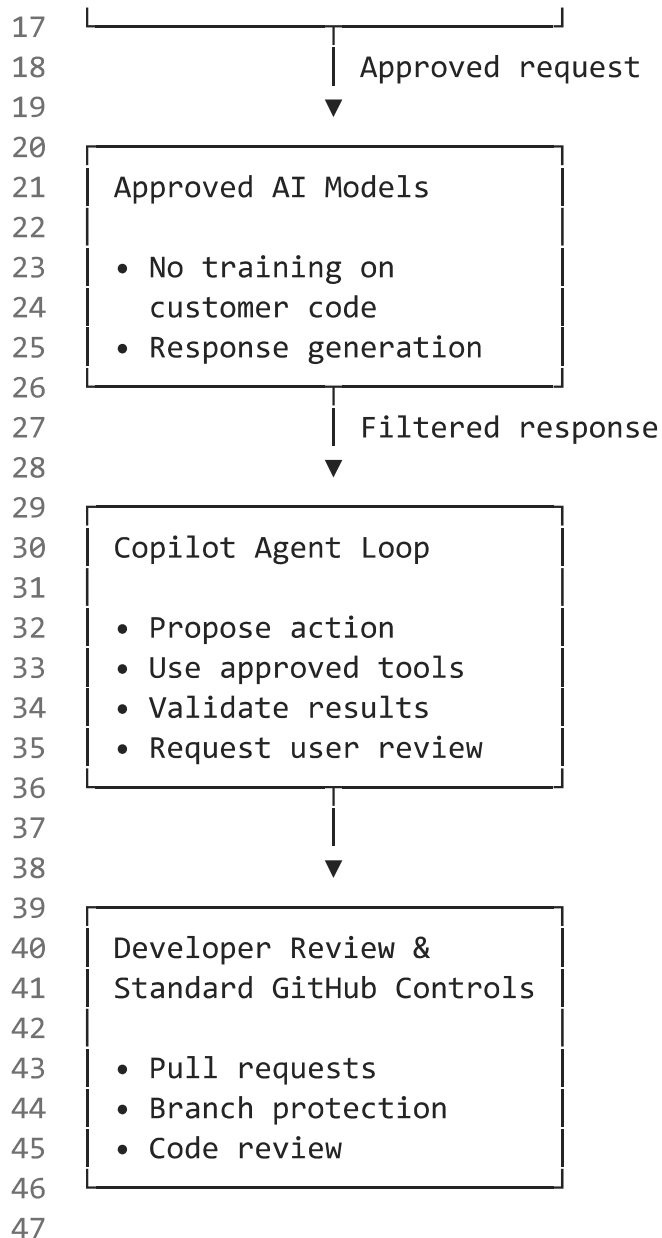
At a high level, the agent loop:

1. Understands the user's goal
2. Plans the next action
3. Uses approved tools (for example: read a file, suggest an edit, run a test)
4. Evaluates the result
5. Repeats until the task is complete or human input is required

The agent **cannot act outside the permissions of the developer or repository**, and all changes remain under human review and standard GitHub workflows.

CAPI & Agent Loop – Security Architecture Diagram (Approved Language)





Key Security Guarantees

Data Protection

- Prompts and code are encrypted in transit
- Business and Enterprise data is not used for model training

Access Control

- Agents operate only within the developer's permissions

- Repository and organization policies are enforced centrally by CAPI

Human in the Loop

- Agents do not bypass pull requests, reviews, or branch protections
- Developers remain accountable for all changes

Built-in Security Validation (Coding Agent)

- Generated code is automatically analyzed using GitHub security tooling (for example: CodeQL, secret scanning, dependency checks)
-

What Copilot Agents Do Not Do

- Do **not** train on private customer code
 - Do **not** act outside approved tools and permissions
 - Do **not** auto-deploy or merge without human approval
 - Do **not** bypass existing SDLC or compliance controls
-

Authoritative References for Customers

- GitHub Copilot Trust Center: <https://copilot.github.trust.page>
 - GitHub Copilot Security Controls Overview
 - GitHub Copilot Coding Agent Documentation
-

Positioning guidance: This explainer is suitable for CISO, GRC, legal, and regulated-industry conversations (CMMC, FedRAMP, ITAR, SOC 2) and intentionally avoids proprietary implementation details while remaining technically accurate.